

VNAP-Secure Simulation Service

Product requirements: multi-user web service and per-run PKI with butterfly certificate refill

Item	Value
Document	Product requirements document (PRD), draft 0.1
Date	2026-10-07
Owner	Joseph Hunt
Status	Draft for review; phases 1 and 2 (PKI service, station refill) approved to start
Repositories	vnap-secure (harness, vnapctl, docs), vanetza-nap branch jodyhuntatx (socktap patches), C-ITS-PKI (certificate tooling)

1. Summary

VNAP-Secure runs Vanetza-NAP (release2) road-side and on-board unit simulations with C-ITS security, pseudonym changes and a passive tracking attacker (the eavesdropper), driven today by a command-line tool, vnapctl, on one shared virtual machine. This document describes two developments:

- **A multi-user simulation service** on a cloud-hosted VM: an API layer with built-in user accounts in front of Docker, used through a web UI (and later by automation such as Claude through the same API).
- **A per-run PKI with certificate refill:** each run gets its own certificate authority. Stations start with a fixed batch of butterfly-expanded authorization tickets and request a new batch when only a few unused ones are left, instead of recycling a fixed set. The time to refresh certificates becomes a measured quantity.

2. Background: current state

2.1 What exists

Component	State (vnap:r2-p17, vnap-secure main)
Stations (socktap)	Vanetza-NAP release2 with patches: v2/v3 security with chain verification, thread-safety fixes, pseudonym pools changed by events on an MQTT control channel, ETSI TS 102 723-8/-9 ID change notification (certificate, MAC, GN address and stationId change together), random silent periods, position control channel (vehicle movement), CAM kinematics fixes, CAM timer restarted at a random phase on every ID change
vnapctl	Scenario files (TOML): validate, up, down, status, events, check; parallel instances (--instance N) with separate networks; ownership labels; helper images rebuilt when their sources change
Helper containers	control broker and pseudonym event client (vnap-pseudo-ctl), mobility client with routes, random turns and mix-zone triggers (vnap-mobility), eavesdropper (vnap-eavesdropper)
Eavesdropper	passive listener on the V2X network only; links pseudonyms by shared identifiers, CAM timing phase and position continuity; replay of saved captures
Certificates	fixed files in vnap-certs/c-its-pki generated once with C-ITS-PKI (root, EA, AA, TLM, a regular AT, 24 butterfly ATs valid 7 days). Every run reuses the same files; a pool wraps around to its first certificate when used up
Results	TestSummaries/: convoy and intersection mix-zone tests, scored against ground truth

2.2 Findings that shape this work

- Full ID change, silent periods and mix zones with random turns defeat the eavesdropper's current techniques (vnap:r2-p17: 12 links, none correct, in the random-turn mix zone).
- Side channels matter: the CAM timer phase linked 16 of 16 changes until it was rephased; a fixed turning pattern lets an attacker undo position-linking mistakes.

- The fixed certificate set is unrealistic and itself a linkage risk: pools wrap around and reuse identities, and every run uses the same 24 certificates, so captures of different runs share identities.
- The shared VM relies on trust: anyone with Docker access is effectively root, and instance numbers, image tags and ownership labels are advisory.

3. Goals and non-goals

3.1 Goals

- G1: Users run, observe, control and evaluate simulations through a web UI, isolated from each other, without shell or Docker access.
- G2: Certificate handling approximates a real deployment: one PKI per run, butterfly key expansion, station-initiated batch refill, no certificate reuse.
- G3: Certificate refresh time, batch issuance time and certificate starvation are measured and reported per run.
- G4: Users author scenarios without knowing addresses, MACs, file paths or container details.
- G5: Existing scenarios, test results and the command-line workflow remain reproducible.

3.2 Non-goals (this release)

- Federated or external identity providers (built-in accounts only).
- Real radio hardware, multiple hosts or Kubernetes.
- Certificate revocation, misbehaviour reporting and linkage-value (LA) based revocation.
- Encrypted delivery of certificate batches between PKI and station (the control channel stands in for the backend link).

4. Users and roles

Role	Can
Admin	manage accounts and quotas; reset passwords; manage the scenario catalogue, approved images and certificate policy limits; see and stop all runs; read the audit log
User	create, start, stop and delete own runs; author scenarios; send control actions to own runs; view and download own results
Viewer	view runs and results shared with them; no control actions

5. Requirements

MUST requirements are needed for the release; SHOULD requirements are expected unless there is a reason not to; MAY requirements are optional.

5.1 Platform and deployment

ID	Requirement	Priority
PLAT-1	Runs on a single cloud-hosted VM with expanded disk and memory, Docker CE (not the snap package), the repositories cloned locally.	MUST
PLAT-2	Only HTTPS (443) is exposed, through a reverse proxy with TLS; MQTT brokers and simulation networks are not reachable from outside.	MUST
PLAT-3	The API service runs as a dedicated system user and is the only component with access to the Docker socket.	MUST

ID	Requirement	Priority
PLAT-4	Station and helper images are built on the VM or pulled from a private registry; station images are referenced by immutable tags (e.g. vnap:r2-p17), not latest.	MUST
PLAT-5	Backups of the database and of retained results.	SHOULD

5.2 Accounts and authentication

ID	Requirement	Priority
AUTH-1	Built-in username and password accounts; passwords hashed with Argon2id; no plaintext or reversible storage.	MUST
AUTH-2	Accounts are created by an admin (no self-registration); password resets are admin-initiated.	MUST
AUTH-3	Session cookies are HttpOnly, Secure and SameSite; state-changing requests are protected against CSRF.	MUST
AUTH-4	Failed logins are rate-limited and repeated failures lock the account temporarily.	MUST
AUTH-5	Every security-relevant action (login, run start/stop, control action, account change) is written to an audit log.	MUST
AUTH-6	API tokens for automation (scoped to one user, revocable).	SHOULD
AUTH-7	Optional TOTP second factor.	MAY

5.3 Runs and multi-user operation

ID	Requirement	Priority
RUN-1	Each run is owned by one user; only the owner, viewers it is shared with and admins can see it.	MUST
RUN-2	Instance numbers (networks, subnets, container names) are allocated atomically by the service; users never choose them.	MUST
RUN-3	Per-user quotas: concurrent runs, maximum run duration (runs are stopped automatically at the limit), disk for retained results.	MUST
RUN-4	Every container has CPU and memory limits.	MUST
RUN-5	Starting and stopping runs are asynchronous jobs with visible progress; a failed start rolls back everything it created.	MUST
RUN-6	A run records the exact scenario, overrides, image tags and seeds it was started with, so it can be repeated.	MUST
RUN-7	Helper images are tagged by the digest of their sources, so different versions never overwrite each other.	MUST

5.4 Scenario authoring

Today a scenario is a TOML file that names IP addresses, MACs, station IDs and certificate paths. Users should not need any of these. Three authoring levels share one validator and one scenario model:

Level	For	How
Templates	most users	pick a catalogue scenario (e.g. random-turn mix zone) and set its exposed parameters: number of vehicles, speeds, silent period, certificate policy, eavesdropper techniques and windows
Builder	custom scenarios	add stations in forms; draw routes, crossings and mix zones on a map; the builder produces the scenario
Expert	power users	edit the generated scenario text directly, validated as it is typed

ID	Requirement	Priority
SCN-1	The scenario format has a machine-readable schema from which the UI builds its forms.	MUST
SCN-2	Validation returns structured errors (field path and message) and reports every problem at once.	MUST
SCN-3	The service assigns addresses, MACs, station IDs and container names; users may not set them.	MUST
SCN-4	Privileged fields (image, container environment, certificate directories, endpoint) are admin-only; user scenarios may only use approved images and an allow-list of settings.	MUST
SCN-5	A dry run shows what a scenario would start without starting it.	SHOULD
SCN-6	The fixed-file certificate pools remain available to admins for reproducing earlier results.	SHOULD

5.5 Certificates and PKI

Each run gets its own PKI, created when the run starts and destroyed, with all its keys, when the run is removed. Certificates are authorization tickets (ATs) issued by butterfly key expansion (BKE, IEEE 1609.2.1 / ETSI), using the C-ITS-PKI implementation.

ID	Requirement	Priority
PKI-1	Per run: a root CA, enrolment authority (EA) and authorization authority (AA) are generated at start; stations trust that root.	MUST
PKI-2	Each pseudonym station is enrolled (caterpillar keys) and receives an initial batch of BKE ATs before it starts. Default: 8.	MUST
PKI-3	Road-side units receive a regular AT from the run's AA.	MUST
PKI-4	A station requests a new batch when its unused ATs drop to a threshold. Default threshold: 2 unused. Default batch size: 8. All three values are configurable per scenario.	MUST
PKI-5	At most one request is outstanding per station; requests are retried with backoff when unanswered.	MUST
PKI-6	Delivered ATs are added to the station's pool while it runs and are chain-checked like the initial ones; the pool never wraps around to a used AT.	MUST
PKI-7	If the pool is empty when a change is due, the station keeps its current AT and refuses the change with a recorded reason (starvation).	MUST
PKI-8	Each batch uses a new expansion period (i-value), so no two ATs of a station share derivation inputs.	MUST
PKI-9	AT validity covers the run; validity periods are compressed to the run's time scale.	MUST
PKI-10	Phase A: the PKI service returns the ATs and their private keys. Phase B: the station derives the private keys itself from its caterpillar key, the expansion value and per-AT offsets returned by the AA, so the PKI never knows them.	MUST (A), SHOULD (B)
PKI-11	Run PKI material is stored on a per-run volume, mounted read-only into stations where possible, and deleted with the run.	MUST

5.6 Certificate metrics

ID	Requirement	Priority
MET-1	Refresh time: from a station's batch request to the batch being installed in its pool, per request; reported as count, mean, max and distribution per run.	MUST
MET-2	Issuance time at the PKI per batch, and batch size, so refresh time can be related to batch size.	MUST
MET-3	Requests, batches, retries, failures and starvation events (refused changes) per station.	MUST
MET-4	Unused ATs per station over time.	SHOULD
MET-5	The metrics are available in status, events, checks (expectations such as no starvation) and the results view.	MUST

ID	Requirement	Priority
MET-6	A batch-size sweep (e.g. 4, 8, 16, 32) can be run as one experiment and summarized.	SHOULD

5.7 Live monitoring and control

ID	Requirement	Priority
LIVE-1	Live event stream per run (messages sent and received, verification results, pseudonym and ID changes, PKI events, control actions, errors), filterable by kind and station.	MUST
LIVE-2	Map view of vehicle positions, routes and mix zones; optionally the eavesdropper's tracks.	SHOULD
LIVE-3	Control actions on own runs: pseudonym change, ID lock/unlock, ID change trigger, move vehicle.	MUST
LIVE-4	Each run's control broker uses credentials generated by the service; users never see them.	MUST

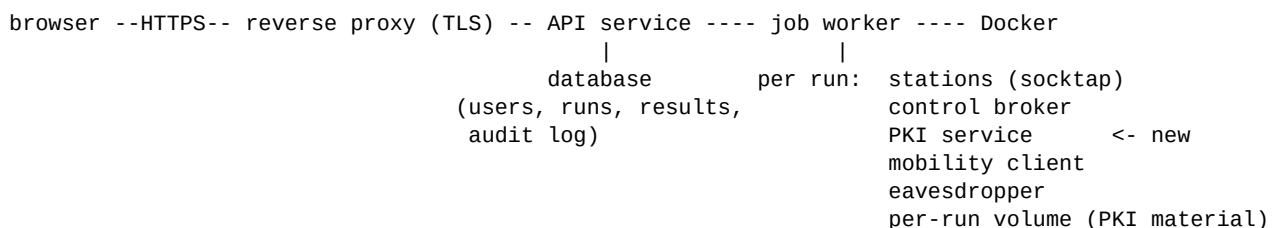
5.8 Results and evaluation

ID	Requirement	Priority
RES-1	Check verdicts with default and scenario expectations.	MUST
RES-2	Eavesdropper results per technique (identifiers, timing, position), scored automatically against ground truth (correct and wrong links, track purity).	MUST
RES-3	Download of captures, logs and generated test summary documents.	SHOULD
RES-4	Repeated runs of one configuration with different seeds, aggregated.	SHOULD

5.9 Security

ID	Requirement	Priority
SEC-1	No user-controlled value reaches a container command line, mount or image reference without validation against an allow-list.	MUST
SEC-2	Private keys never leave the server and are never shown in the UI or logs.	MUST
SEC-3	Secrets reach containers only through the environment or mounted files, never as command-line arguments or labels.	MUST
SEC-4	Runs are isolated by network: a run's containers cannot reach another run's networks.	MUST

6. Architecture



- **vnapctl as a library:** scenario model and validation, up/down, status, events, check and the eavesdropper reports move into a Python package; the command-line tool and the API service both use it.
- **API service:** FastAPI (Python, like vnapctl), OpenAPI description, session and token authentication; SQLite at first, Postgres when needed. Long operations run in a worker.
- **PKI service (new):** a container per run wrapping C-ITS-PKI. It creates the run's CA hierarchy, enrolls stations, issues initial batches and answers refill requests on the run's control broker.
- **Stations:** socktap gains a growing pseudonym pool and a PKI request/response handler on its existing control connection.

7. Certificate refill protocol

The control broker stands in for the backend link between a vehicle and its PKI (in a deployment, a cellular or internet connection authenticated with the enrolment credential). It is not part of the V2X network, so the eavesdropper does not see it. Topics use the station's configured ID, which stays fixed across ID changes, like the existing pseudonym and position topics.

Message	Topic	Content
Request (station to PKI)	vnap/pki/<station>/request	request_id, unused count, requested batch size, time sent
Batch (PKI to station)	vnap/pki/<station>/batch	request_id, i-period, ATs (encoded certificates); phase A also the private keys, phase B the expansion offsets instead; issuance time in ms
Error (PKI to station)	vnap/pki/<station>/batch	request_id, error text; the station retries with backoff

```

station                                     PKI service
| unused ATs <= threshold (default 2)      |
|-- request {request_id, unused, count} -->| BKE: expand caterpillar keys for i-period k,
|                                           | AA issues `count` ATs (default 8)
| <-- batch {request_id, ATs, keys} -----|
| add to pool, chain check, log refresh time|

```

Station log lines (examples): [PKI] batch requested (2 unused, 8 wanted), [PKI] batch installed: 8 certificate(s), 412 ms after request, [PKI] pool empty: change refused. vnapctl derives the metrics in section 5.6 from these lines and the PKI service's log.

8. Delivery plan

Phase	Content	Acceptance criteria
1. PKI service	container wrapping C-ITS-PKI: per-run root, EA, AA; enrolment; initial batches; RSU AT; refill requests over MQTT; issuance timing; any service mode needed in C-ITS-PKI	a run's stations trust only that run's root; initial batches of the configured size; a request is answered with a valid batch of new ATs; issuance time logged
2. Station refill (option A)	socketap: pool that grows at runtime, unused tracking, request at threshold, no wrap-around, starvation handling, [PKI] logs, chain check of new ATs; ThreadSanitizer run	over a run longer than one batch, no AT is used twice; refresh time logged per request; all regression scenarios pass; no new ThreadSanitizer reports
3. vnapctl	certificate policy in scenarios (initial 8, refill at 2, batch 8 by default); PKI provisioning and per-run volume; teardown deletes keys; PKI events, metrics and checks; fixed pools as expert option	mix-zone scenarios run with per-run PKI; status and check show refresh metrics; earlier scenarios still run with fixed pools
4. Measurement	mix-zone reruns with per-run PKI; batch-size sweep; test summary	summary relates refresh time to batch size
5. Station key derivation (option B)	BKE private key derivation in socketap; PKI returns offsets instead of keys	PKI holds no AT private keys; derivation time included in refresh time
6. vnapctl library	package split; schema and structured validation; service-assigned addresses; allow-lists; atomic instance allocation; content-addressed helper images	CLI behaviour unchanged; validator returns field-level errors
7. API service	accounts, roles, runs, quotas, jobs, events stream, control actions, results, audit log	requirements AUTH, RUN, LIVE, RES, SEC met for the API
8. Web UI	runs list, scenario templates and builder with map, live view, control, results	a user can author, run, observe and evaluate a scenario without the command line
9. Hardening	backups, TOTP, MCP endpoint for automation	-

9. Risks and open questions

Topic	Notes
Option A realism	the PKI knows the stations' private keys and derivation cost is missing from refresh time; refresh-time results should be confirmed after option B
Time compression	real batches cover weeks; runs last minutes. Validity, i-periods and refill timing are scaled; the scaling must be stated with every result
PKI load	batch issuance is CPU-bound; many stations requesting at once (synchronized changes in a mix zone) will queue. This is a finding to measure, not to hide
Enrolment realism	real enrolment and AT requests are encrypted and authenticated with the enrolment credential and go through a registration authority; the control channel simplifies this
Retention	how long runs, captures and summaries are kept per user, and what is deleted with a run (PKI keys always)
UI technology	to be chosen in phase 8 (server-rendered pages or a single-page application)